CyBOK

Penetration testing
Tools and trix

Joakim Kävrestad
Jönköping School of Engineering
joakim.kavrestad@ju.se

© Crown Copyright, The National Cyber Security Centre 2023. This information is licensed under the Open Government Licence v3.0. To view this licence, visit https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

When you use this information under the Open Government Licence, you should include the following attribution: CyBOK memory analysis workshop slides © Crown Copyright, The National Cyber Security Centre 2023, licensed under the Open Government Licence: https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

Litterature note

- This lecture is based on the following CyBOK knowledge areas:
  - Malware and Attack Technologies
  - Adversarial Behaviours

- Tools are documented on their own web- and/or man-pages

Agenda

- Cyber kill chain revisited
- Generic attack model
- Tools for pentesting

Pentesting – Cyber kill chain

CyBOK

- 1. Reconnaissance
  - Identify and select target. Often includes both OSINT and network scanning
- 2. Weaponization
  - Preparation of the attack payload
  - Involves getting or creating the weapons for the attack. Could mean downloading a tool or developing something own

Pentesting – Cyber kill chain

CyBOK

- 3. Delivery
  - Find a way to deliver the payload to the target
  - This can be phishing, drive by download or a direct network communication

- 4. Exploitation
  - Trigger the payload
  - Have it run somehow, this can be dependent on a user action (phishing) or using a vulnerability in the target

Pentesting – Cyber kill chain

CyBOK

- 5. Installation
  - Installation of a backdoor or Remote Access Trojan to maintain access
- 6. Command and Control (C2)
  - Establish infrastructure to enable C2 access to the compromised host
- 7. Actions on objectives
  - With access to the target device the attacker can fulfill her original objectives
  - Ransom, data exfiltration, …

Pentesting – general metod

- Cyber kill chain is meant to describe adversarial attacks
- Quite good to describe a pentest, but maybe not 100% accurate
- Lets look at a somewhat modified attack model

Pentesting – Info gathering

- The first step involved **information gathering** from open sources
  - **OSINT:** Open source intelligence

- This can include numerous different tasks all looking to gain information about the target
  - Google
  - Job adverts
  - Social media
  - …

Pentesting – Enumeration

CyBOK

- **Enumeration** is about scanning the target to know more about its technical properties

- Typical tasks include
  - Scanning IP ranges for responding hosts
  - Looking for open ports
  - Trying to figure out what software targets are running
  - ….

Pentesting – Exploitation

- **Exploitation** about finding and using vulnerabilities
- This is the step when we try to get access to systems – get a foothold
- Often involves using or building exploits

Pentesting – Priv Esc

- **Privilege Escalation** is all about expanding system access
- **Horizontal** means that you gain access to another account with similar permissions
- **Vertical** means that you get access to accounts with other different permissions (often higher)

Pentesting – Post-exploitation

CyBOK

- **Post-exploitation** is when a true attacker would realize their attack objectives

- As a pentester, you
  - Evaluate if you can use you access to target other hosts (pivoting)
  - See what additional information we can gather
  - Cover tracks
  - Report

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Pentesting – Cyber kill chain

CyBOK

- The cyber kill chain is extensive and developed to describe sophisticated attacks
- It has been critiques as inflexible
  - In reality, attackers may skip or combine steps
- Should be seen as one of several tools

Pentesting – Infection vectors

- Paths taken to infect victims
- The approach used to expose victims, or victim machines, to malicious content or actions
- **Malicious attachments** is possibly the oldest, where you deliver you payload as a message attachment

Pentesting – Infection vectors

- **Black hat Search Engine Optimization (SEO)** is all about creating malicious websites and making them appear high in search lists for trending keywords

- **Drive-By download** exploit users web browsers to make them automatically download malicious content when visiting a web site

- **Compromise vulnerable devices**

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Pentesting – Toolbox!

CyBOK

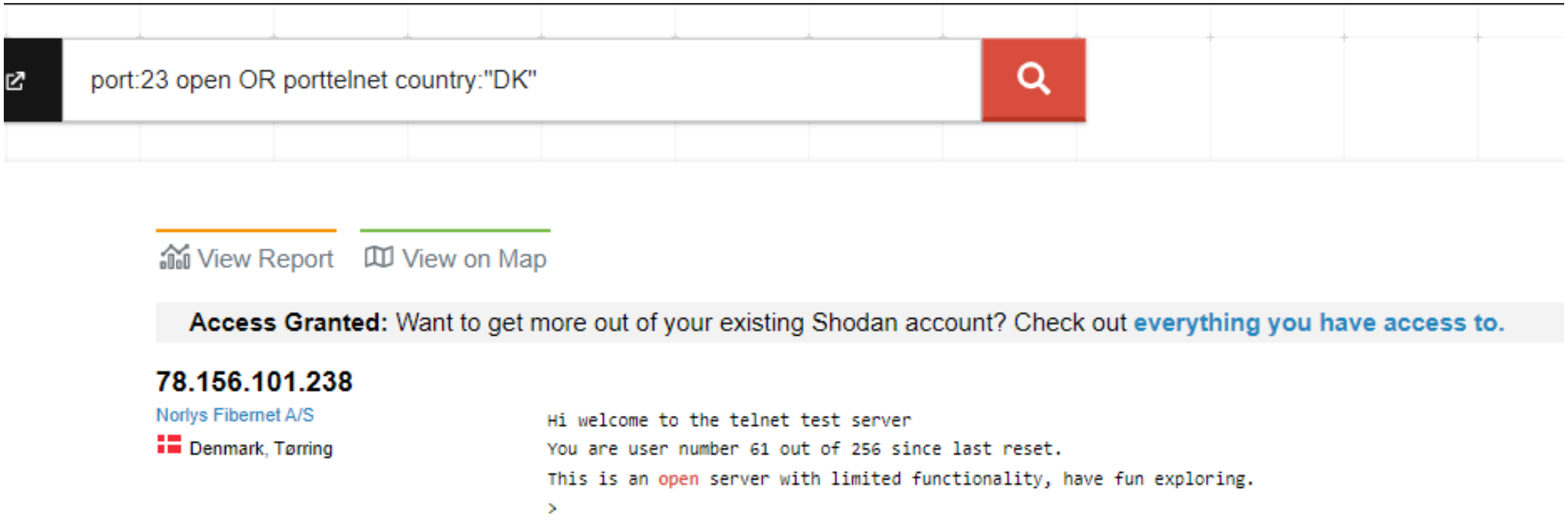
- Pentesting is a game where more tools are better
- We will look at *some* of the most important
- There are some pentesting linux dists out there, preconfigured with large toolboxes
  - Kali
  - BlackBox
  - Parrot OS
  - …

Pentesting – Toolbox - Shodan

CyBOK

- Online tool for searching for devices connected to the internet
- Collects information from devices connected to the internet by asking them
- Can give you a lot of very helpful information
- A nice thing is that you query the Shodan database rather than actively perform searches against a network

Pentesting – Toolbox - Shodan



Pentesting – Toolbox - Shodan

Shodan | Maps | Images | Monitor | Developer | More...

SHODAN | Explore | Downloads | Pricing | hostname:ju.se | Account

TOTAL RESULTS

33

TOP ORGANIZATIONS

HJ.SE network	20
HJ.SE network Jonkoping, SWEDEN	8
HJ.SE ipv6 network	3
Koneo	1

TOP PRODUCTS

Microsoft IIS httpd	7
Microsoft HTTPAPI httpd	5
nginx	4
Apache httpd	3
Cisco ASA SSL VPN	1

More...

View Report | View on Map

Access Granted: Want to get more out of your existing Shodan account? Check out **everything you have access to.**

193.10.239.254

2023-10-19T08:40:03.344789

ju-fg-bb2.bb2.hj.se
ju-fg2.dc.hj.se
vpn.ju.se
vpn.hj.se
ju-fg1.dc.hj.se
HJ.SE network
Sweden, Jönköping

SSL Certificate

Issued By:
|- Common Name:
GEANT OV RSA CA 4
|- Organization:
GEANT Vereniging

Issued To:
|- Common Name:
vpn.ju.se
|- Organization:
Stiftelsen Högskolan i Jönköping

Supported SSL Versions:
TLSv1.2, TLSv1.3

Diffie-Hellman Fingerprint:
RFC3526/Oakley Group 14

```
HTTP/1.1 200 OK
Date: Thu, 19 Oct 2023 08:41:55 GMT
ETag: "83-651328ab"
Accept-Ranges: bytes
Content-Length: 131
Content-Type: text/html
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self'; object-src 'self'; script-src 'self' https:  'unsafe-eval' 'unsafe-inline' b...
```

GRC Suite - interface utilisateur configurable, container : ACADEM

2023-10-19T00:13:05.828011

193.11.6.37
academp.win.hj.se
academ.ju.se
HJ.SE network Jonkoping, SWEDEN
Sweden, Jönköping

SSL Certificate

Issued By:
|- Common Name:
GEANT OV RSA CA 4
|- Organization:
GEANT Vereniging

Issued To:
|- Common Name:
academp.win.hj.se
|- Organization:
Stiftelsen Högskolan i Jönköping

Supported SSL Versions:
TLSv1.2, TLSv1.3

```
HTTP/1.1 200
Server: nginx/1.24.0
Date: Thu, 19 Oct 2023 00:13:04 GMT
Content-Type: text/html;charset=UTF-8
Content-Length: 14750
Connection: keep-alive
Set-Cookie: JSESSIONID=F5BFAA5625B45B0E46252EE3A0A60B8E; Path=/r1customui7; HttpOnly
Pragma: no-cache
Cache-Control: no-cache
Cache-Co...
```

Pentesting – Toolbox – NMAP/ZENMAP

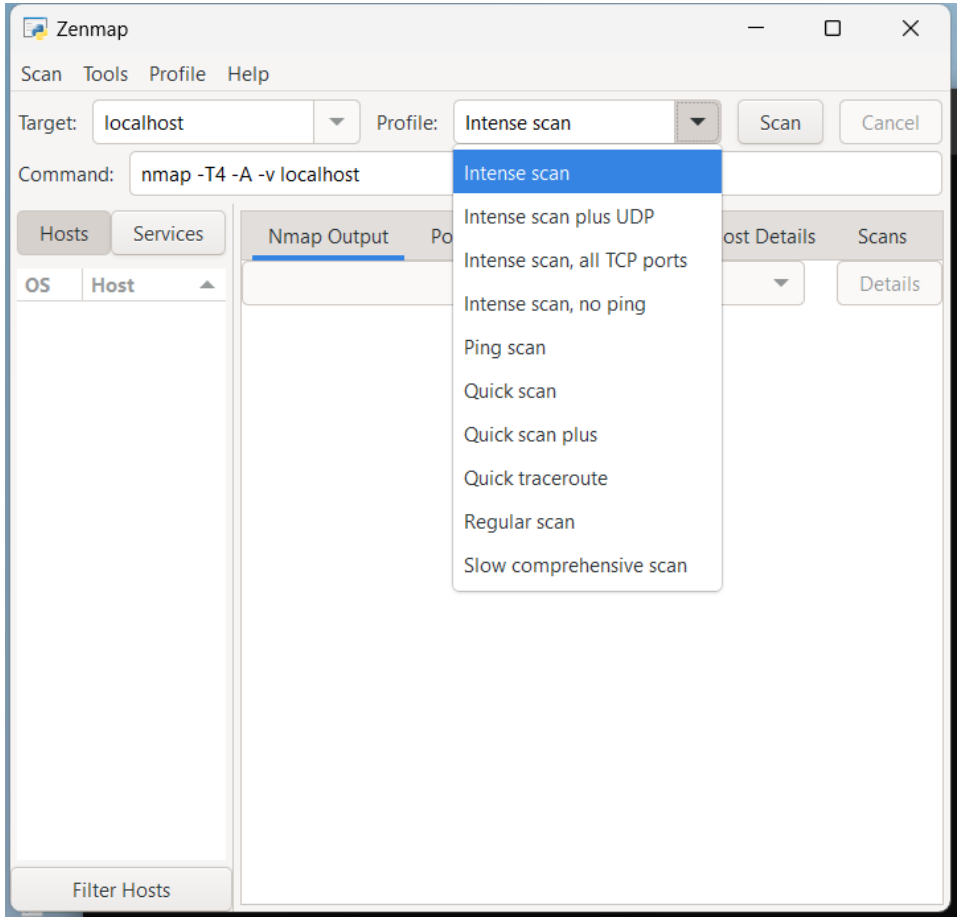
CyBOK

- Network scanning tool
  - Scanning for active hosts
  - Open ports
  - And sometimes identify OS and service software

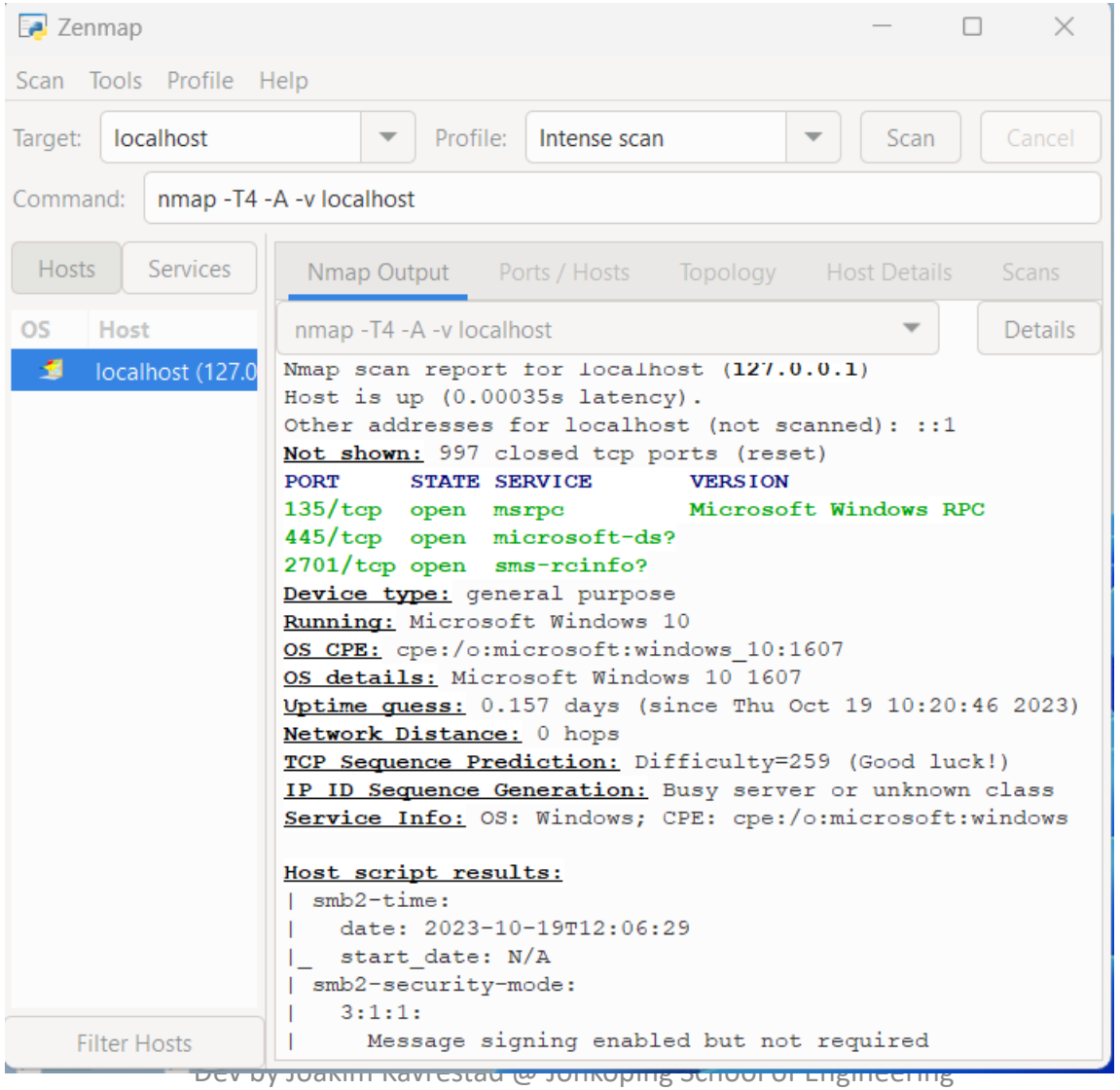
- By figuring out the info above, we can search for suitable vulnerabilities to use

- NMAP: CLI utility
- ZENMAP: Somewhat limited GUI

Pentesting – Toolbox – NMAP/ZENMAP



Pentesting – Toolbox – NMAP/ZENMAP



Pentesting – Scanning intensity

CyBOK

- When you actively poke and probe a network, there is certainly a chance that you will be detected

- Active recon means that you are interacting directly with the target system
  - NMAP

- Passive recon means that you are not directly interacting with the target system
  - Shodan and other OSINT

Pentesting – Scanning intensity

- Even with active scanning you can decide upon the level of intensity/aggression
- Typically, a more intense scan will yield more data and be quicker, but is also easier to detect
- One typically starts carefully and then intensify as needed to yield results

Pentesting – Toolbox - Terminal

CyBOK

- There are many Linux command (and Windows, I guess) which are useful for recon
  - Ping
  - Dig
  - Nslookup
  - Traceroute
  - Telnet
  - Nc

- …..

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Pentesting – Toolbox - Metaspolit

- Penetration testing framework
- Available as open source and in commercial edition
- Can do some searching, but is primarily a tool for exploiting vulnerable systems

Pentesting – Toolbox - Metaspolit

CyBOK

- Three components
  - **Msfconsole** which is the main interface
  - **Modules** which includes exploits, scanners and more
  - **Tools** which are, well, stand-alone supporting tools

- Often used once you found something to exploit

- Started from the command line using the *msfconsole* command

Pentesting – some terminology

- An **exploit** is a code which uses a system vulnerability
- A **vulnerability** is a flaw in code, design, or logic which can be exploited
- A **payload** is some code which will run on the targed system (the actions carried out after using the exploit)

Pentesting – Toolbox - Metaspolit

CyBOK

- Metaspolit is started using *msfconsole*
- You can use your typical Linux command when in the Metaspolit interface
- And of course, all the Metasploit functionality
- The is a helpful help-function: *help*

Pentesting – Toolbox - Metaspolit

CyBOK

- Metasploit is context aware, what you can do depends on your current context

- A common use case is to launch an exploit to exploit a possibly vulnerable host
  - *Use [exploit]*
  - You can now configure the exploit with targets, payloads etc

- But lets explore Metasploit further by testing!

Pentesting – Toolbox - Hydra

- Online password-cracking tool
  - Allows you to automate password guessing attacks on websites
- Command line tool
- Basic syntax: hydra –l *account* –p *password target*
  - Hydra –l admin –p summer ftp://10.10.10.1/

Pentesting – Password guessing?

- Password guessing is all about trying to guess account passwords to get account access

- Brute force
  - Try all possible key combinations

- Dictionary
  - Try all entries in a list

- Mask
  - Specify a password structure, much like a regular expression

Pentesting – Password guessing?

- There are also hybrid attacks combining two or more attack types
- Offline attacks mean that a password hash is extracted and the attack is carried out offline
- Online attack mean that the password guessing is launched at a running system

Pentesting – Toolbox - Hydra

CyBOK

- You can supply individual accounts or passwords, or lists of the same
  - -l for single account
  - -L for list of accounts
  - -p for single password
  - -P for list of passwords
- You can also specify a list of account-password combinations using –C (and no –l,-L,-p, or-P)
  - List should contain line-separated *account:password* entries
  - Useful for testing default credentials
- There is some more you can do, but that can be explored in the lab

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Thank you for today!